

BENIGN-POSITIVE TRIAGE & FALSE-POSITIVE TUNING

TAXONOMY CORRECTED: SUSPICIOUS BUT EXPECTED

Twenty-five suspicious-but-expected scenarios that demonstrate disciplined closure, narrow tuning, and false-negative guardrails.

25

CONTROLLED SCENARIOS

6

EVIDENCE DOMAINS

5

DECISION STAGES

0

PRODUCTION IMPACT

CLASSIFICATION SCOPE

Methodology verified. Execution evidence was not supplied for independent validation.

Marc Lavoie

Cybersecurity Portfolio | SOC Analysis and Detection Engineering

INDEPENDENT CLASSIFICATION REVIEW

Verification memo

The supplied report was audited against current Microsoft Sentinel incident-classification guidance and the evidence described in each scenario.

CLASSIFICATION LOGIC

VERIFIED

Each scenario defines an alert condition, corroborating telemetry, and controlled ground truth that can support the stated analyst decision.

EXECUTION EVIDENCE

NOT INCLUDED

No incident IDs, timestamps, exported KQL results, screenshots, or raw event records were supplied. Execution cannot be independently confirmed.

PUBLICATION SAFETY

PUBLIC-SAFE

Examples use synthetic identities, lab hosts, reserved addresses, and nonproduction scenarios. No live tenant or company data is required.

AUDIT CONCLUSION

The twenty-five scenarios are more precisely BENIGN POSITIVES because the detection can fire correctly on suspicious-but-expected activity. Microsoft reserves FALSE POSITIVE for incorrect alert logic or inaccurate data. The revised report keeps both concepts and shows when to tune each one.

DECISION DISCIPLINE

One alert, four possible outcomes

A high-quality SOC disposition explains both what the detection observed and why the underlying activity should be treated as malicious, expected, incorrect, or unresolved.

TRUE POSITIVE**Suspicious activity**

The alert is supported by malicious ground truth, scope, impact, or adversary-controlled follow-on behavior.

BENIGN POSITIVE**Suspicious but expected**

The alert logic is reasonable, but a known actor, asset, change, or exercise explains the behavior.

FALSE POSITIVE**Incorrect logic or data**

The rule fired because its logic is wrong for the intended use case, or the supporting data is inaccurate.

UNDETERMINED**Evidence incomplete**

The investigation cannot yet prove malicious intent, expected business context, or a detection defect.

ANALYST GUARDRAIL

Never create a broad allowlist merely because an event was expected once. A useful exception is specific, time-bounded, reviewable, and designed so a real attack still produces signal.

ANALYST WORKFLOW

Five-stage decision framework

The same workflow applies to every scenario. The disposition changes only after the evidence and ground truth converge.

1

VALIDATE

Confirm rule, timestamp, severity, source, and affected entities.

2

SCOPE

Identify users, hosts, files, destinations, and the investigation window.

3

CORRELATE

Pivot across process, file, registry, identity, DNS, network, and cloud data.

4

GROUND TRUTH

Test the activity against change records, lab plans, ownership, and observed impact.

5

DISPOSITION

Close with rationale, response actions, tuning decision, and next validation step.

EVIDENCE DOMAINS

Identity: SigninLogs / AuditLogs | Execution: DeviceProcessEvents | Change: DeviceFileEvents / DeviceRegistryEvents | Network: DeviceNetworkEvents / CommonSecurityLog | Cloud: AzureActivity / OfficeActivity | Case: SecurityAlert / SecurityIncident

COVERAGE MAP

Twenty-five investigation patterns

Each pattern includes an evidence set, ground-truth test, immediate response, and narrow tuning guardrail.

01 Encoded PowerShell Endpoint T1059.001	14 DNS tunneling behavior Network T1071.004
02 PsExec lateral movement Endpoint T1569.002	15 DGA-like NXDOMAIN burst Network T1568.002
03 Scheduled task persistence Endpoint T1053.005	16 RDP brute-force pattern Identity T1110
04 Registry run-key persistence Endpoint T1547.001	17 Password spray Identity T1110.003
05 Rundll32 LOLBin execution Endpoint T1218.011	18 Impossible travel Identity Credential access context
06 Certutil download behavior Endpoint T1105	19 MFA fatigue Identity T1621
07 Data staging and archive creation Endpoint T1560.001	20 New administrative account Identity T1136
08 Ransomware-like mass file changes Endpoint T1486	21 Privileged role assignment Cloud T1098
09 WMI remote execution Endpoint T1047	22 Suspicious OAuth consent Cloud T1528
10 PowerShell remoting and WinRM Endpoint T1021.006	23 Mass SharePoint download M365 T1530
11 Network port scanning Network T1046	24 Suspicious mailbox rule M365 T1114
12 SMB reconnaissance Network T1135	25 Azure firewall or NSG change Cloud T1562.007
13 Command-and-control beaconing Network T1071.001	

SCENARIO SET 01-05

Endpoint and adjacent telemetry

01 Encoded PowerShell PRIMARY EVIDENCE DeviceProcessEvents, DeviceNetworkEvents, DeviceFileEvents ACTION Limit any exception to the exact script hash, actor, host, and test window.	ENDPOINT T1059.001 GROUND-TRUTH TEST Known command and script hash, lab account, approved window, and no harmful follow-on activity.
02 PsExec lateral movement PRIMARY EVIDENCE DeviceProcessEvents, DeviceNetworkEvents, DeviceLogonEvents ACTION Match the approved source, destination, account, ticket, and time window.	ENDPOINT T1569.002 GROUND-TRUTH TEST Approved administrator, known endpoints, expected service traffic, and harmless child process.
03 Scheduled task persistence PRIMARY EVIDENCE DeviceProcessEvents, SecurityEvent, DeviceFileEvents ACTION Scope exceptions to the exact task path, signer, creator, and maintenance window.	ENDPOINT T1053.005 GROUND-TRUTH TEST Expected task name, approved creator, harmless program, and documented test period.
04 Registry run-key persistence PRIMARY EVIDENCE DeviceRegistryEvents, DeviceProcessEvents ACTION Use the exact key, value, process signer, account, and expiration time.	ENDPOINT T1547.001 GROUND-TRUTH TEST Temporary lab Run key, authorized account, known value, and harmless executable.
05 Rundll32 LOLBin execution PRIMARY EVIDENCE DeviceProcessEvents, DeviceImageLoadEvents, DeviceNetworkEvents ACTION Do not allowlist rundll32 globally; bind tuning to signer, DLL path, parent, and use case.	ENDPOINT T1218.011 GROUND-TRUTH TEST Signed Windows component, expected parent, trusted DLL, and no attacker-controlled destination.

SCENARIO SET 06-10

Endpoint and adjacent telemetry

06 Certutil download behavior

ENDPOINT | T1105

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceNetworkEvents, DeviceFileEvents

ACTION

Use the exact server, file hash, account, and short validation window.

GROUND-TRUTH TEST

Harmless file from an approved lab server with expected hash and no execution chain.

07 Data staging and archive creation

ENDPOINT | T1560.001

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceFileEvents, DeviceNetworkEvents

ACTION

Tune only the approved test path, process, archive name, and scheduled window.

GROUND-TRUTH TEST

Dummy files in the lab directory, known utility, expected archive, and no outbound transfer.

08 Ransomware-like mass file changes

ENDPOINT | T1486

PRIMARY EVIDENCE

DeviceFileEvents, DeviceProcessEvents, DeviceNetworkEvents

ACTION

Restrict exclusions to the isolated lab path and signed simulator; never suppress impact telemetry.

GROUND-TRUTH TEST

Bulk changes touch only disposable lab files and are caused by the approved simulator.

09 WMI remote execution

ENDPOINT | T1047

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceLogonEvents, DeviceNetworkEvents

ACTION

Require the approved management host, admin identity, target set, and change record.

GROUND-TRUTH TEST

Authorized administrator, known source and target, expected time, and harmless command.

10 PowerShell remoting and WinRM

ENDPOINT | T1021.006

PRIMARY EVIDENCE

DeviceProcessEvents, DeviceNetworkEvents, DeviceLogonEvents

ACTION

Use constrained endpoint, source host, actor, command purpose, and expiration.

GROUND-TRUTH TEST

Approved administrative query from the management host during a controlled exercise.

SCENARIO SET 11-15

Network and adjacent telemetry

11 Network port scanning PRIMARY EVIDENCE DeviceNetworkEvents, CommonSecurityLog, DeviceProcessEvents ACTION Allow only registered scanner addresses, approved ranges, ticket, and window.	NETWORK T1046 GROUND-TRUTH TEST Known vulnerability scanner, approved target scope, expected tool, and scheduled window.
12 SMB reconnaissance PRIMARY EVIDENCE DeviceNetworkEvents, CommonSecurityLog, DeviceLogonEvents ACTION Tune to the exact scanner, account, share set, and business-approved cadence.	NETWORK T1135 GROUND-TRUTH TEST Inventory scanner or administrator uses approved sources and target scope.
13 Command-and-control beaconing PRIMARY EVIDENCE DeviceNetworkEvents, DeviceProcessEvents, CommonSecurityLog ACTION Match lab host, process hash, destination, interval, and exercise window together.	NETWORK T1071.001 GROUND-TRUTH TEST Controlled script contacts a lab-owned destination at the documented interval with no payload or secondary activity.
14 DNS tunneling behavior PRIMARY EVIDENCE ASimDnsActivityLogs, DeviceNetworkEvents, DeviceProcessEvents ACTION Scope tuning to the controlled zone, source host, process, and short test period.	NETWORK T1071.004 GROUND-TRUTH TEST Authorized generator uses synthetic strings against a controlled lab domain with no production data.
15 DGA-like NXDOMAIN burst PRIMARY EVIDENCE ASimDnsActivityLogs, DeviceProcessEvents, DeviceNetworkEvents ACTION Require the lab process, source, zone, and no-success condition before suppression.	NETWORK T1568.002 GROUND-TRUTH TEST Known test process creates synthetic names in a controlled zone and makes no successful external connection.

SCENARIO SET 16-20

Identity and adjacent telemetry

16 RDP brute-force pattern

IDENTITY | T1110

PRIMARY EVIDENCE

DeviceLogonEvents, SecurityEvent, DeviceNetworkEvents

GROUND-TRUTH TEST

Authorized authentication test uses a dedicated lab account and does not create a usable session.

ACTION

Use dedicated test identities, exact source, target, and window; never tune away success events.

17 Password spray

IDENTITY | T1110.003

PRIMARY EVIDENCE

SigninLogs, IdentityLogonEvents, SecurityAlert

GROUND-TRUTH TEST

Only designated lab identities are tested from the registered source with no production access.

ACTION

Constrain to lab identities, source, failure-only outcome, and test window.

18 Impossible travel

IDENTITY | Credential access context

PRIMARY EVIDENCE

SigninLogs, AuditLogs, SecurityAlert

GROUND-TRUTH TEST

Same lab user and device use known VPN infrastructure with expected authentication context.

ACTION

Maintain a controlled VPN-egress list and still require device and post-authentication review.

19 MFA fatigue

IDENTITY | T1621

PRIMARY EVIDENCE

SigninLogs, AuditLogs, OfficeActivity

GROUND-TRUTH TEST

Controlled MFA testing uses the known account, device, IP, method, and exercise window.

ACTION

Tune only failed or denied prompts in the controlled exercise; never suppress an accepted prompt with impact.

20 New administrative account

IDENTITY | T1136

PRIMARY EVIDENCE

AuditLogs, IdentityDirectoryEvents, SigninLogs

GROUND-TRUTH TEST

Approved lab administrator creates a temporary identity that is removed after testing.

ACTION

Require the approved creator, exact test identity, role, ticket, and removal deadline.

SCENARIO SET 21-25

Cloud and adjacent telemetry

21 Privileged role assignment

CLOUD | T1098

PRIMARY EVIDENCE

AuditLogs, SigninLogs, AzureActivity

ACTION

Use PIM status, role, actor, target, change record, and automatic expiration.

GROUND-TRUTH TEST

Approved PIM or test assignment matches the actor, target, role, ticket, and time window.

22 Suspicious OAuth consent

CLOUD | T1528

PRIMARY EVIDENCE

AuditLogs, SigninLogs, AADServicePrincipalSignInLogs

ACTION

Match application ID, publisher, owner, exact permissions, tenant scope, and expiration.

GROUND-TRUTH TEST

Known lab application has approved owner, minimal permissions, synthetic data, and expected consent.

23 Mass SharePoint download

M365 | T1530

PRIMARY EVIDENCE

OfficeActivity, SigninLogs, DeviceNetworkEvents

ACTION

Tune to the test library, identity, application, device, volume, and no-exfiltration condition.

GROUND-TRUTH TEST

Dummy library, approved account, expected application, corporate lab endpoint, and no external transfer.

24 Suspicious mailbox rule

M365 | T1114

PRIMARY EVIDENCE

OfficeActivity, AuditLogs, SigninLogs

ACTION

Require known owner, internal-only destination, exact rule purpose, and removal time.

GROUND-TRUTH TEST

Controlled rule touches only lab messages or internal test folders and has no external destination.

25 Azure firewall or NSG change

CLOUD | T1562.007

PRIMARY EVIDENCE

AzureActivity, SigninLogs, AuditLogs, CommonSecurityLog

ACTION

Bind exceptions to resource ID, actor, ticket, exact rule delta, window, and verified restoration.

GROUND-TRUTH TEST

Approved administrator changes only a lab resource, within the change window, and restores it.

WORKED INVESTIGATION

Command-and-control beaconing

A repeated outbound pattern is a detection signal, not a final verdict. The analyst must connect timing, process lineage, destination ownership, identity context, and impact.

1

ALERT

SecurityAlert identifies the host, rule, severity, and investigation window.

2

NETWORK

DeviceNetworkEvents and CommonSecurityLog confirm stable periodic connections.

3

PROCESS

DeviceProcessEvents ties the sessions to a process, parent, path, signer, and account.

4

CHANGE

DeviceFileEvents shows when the process and any configuration artifact appeared.

5

CONTEXT

Change records, test plan, destination ownership, and follow-on behavior establish ground truth.

DISPOSITION

BENIGN POSITIVE when the same pattern is produced by the approved simulator, on the registered lab host, to the controlled destination, during the exercise window, with no payload, secondary destination, or impact.

OPERATIONAL QUALITY

From disposition to better detection

The investigation should improve both immediate response and future signal quality. Every closure needs a rationale, owner, evidence list, and reviewable next step.

CLOSE WELL	TUNE NARROWLY	PROTECT RECALL
● Use Benign Positive for suspicious-but-expected activity ● Use False Positive only for bad logic or data ● Record actor, asset, ticket, and time window ● State which evidence disproved compromise	● Prefer multiple attributes over a single allowlist ● Add an owner and automatic expiration ● Keep an audit trail for exceptions ● Retest the original and adjacent attack paths	● Never suppress impact or successful-access signals ● Alert when expected context changes ● Monitor exception volume and age ● Remove stale watchlist entries and test false negatives

MINIMUM CLOSURE NOTE

Disposition + classification reason + alert rule + investigation window + affected entities + telemetry reviewed + ground-truth evidence + observed impact + response taken + tuning decision + owner + follow-up date.

VERIFICATION NOTES

References, limitations, and next proof

WHAT THIS REPORT ESTABLISHES

A technically coherent benign-positive triage and false-positive tuning design across twenty-five suspicious behaviors, aligned to Microsoft Sentinel's distinction between expected activity and incorrect detection logic or data.

WHAT REMAINS TO PROVE

Attach sanitized incident metadata, KQL output, timestamps, entity pivots, and closure evidence from an executed lab. Until then, this is a portfolio engineering design, not independent proof of live execution.

Microsoft Sentinel incident investigation

<https://learn.microsoft.com/en-us/azure/sentinel/investigate-incidents>

Microsoft Sentinel incident classification

<https://learn.microsoft.com/en-us/azure/sentinel/incident-navigate-triage>

Handling false positives in Microsoft Sentinel

<https://learn.microsoft.com/en-us/azure/sentinel/false-positives>

Defender XDR advanced hunting - DeviceProcessEvents

<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>

MITRE ATT&CK data components

<https://attack.mitre.org/datacomponents/>

PORTFOLIO STATEMENT

Prepared by Marc Lavoie as a public-safe cybersecurity portfolio case study. The report demonstrates investigative reasoning, not access to any production tenant or confidential incident.